TryHackMe - Simple CTF

Dificuldade - Fácil

Yuji Kurata Sakatsume 190021276@aluno.unb.br

April 14, 2026

Sumário

1 Visão geral **2**

2 Reconhecimento **3**

2.1 Enumeração de portas 3

2.2 Enumeração de diretórios 4

3 Exploração **5**

4 Escalação de privilégios **7**

5 Conclusão **8**

Apêndice **10**

6 Ferramentas **10**

1 Visão geral

Esse relatório apresenta uma solução para a room Simple CTF, da plataforma TryHackMe. Nesse desafio, foram aplicados procedimentos básicos de enumeração de portas e diretório. Também foi explorada a vulnerabilidade conhecida para extração de credenciais, a partir das quais foi possível acessar o serviço SSH e recuperar as flags.

Inicialmente, foram realizados procedimentos de enumeração de portas com Nmap e varredura de diretórios com Feroxbuster, o que permitiu identificar os serviços ativos (FTP, HTTP e SSH) e descobrir um diretório o qual hospeda o CMS CMS Made Simple, em uma versão vulnerável à CVE-2019-9053.

Com identificação da versão do CMS, foi explorada a vulnerabilidade de SQL injection que possibilita a extração de hashes de senha do banco de dados. Após a quebra do hash obtido, foi possível acessar a área administrativa do CMS e, posteriormente, obter acesso ao sistema via SSH. A escalação de privilégios foi concluída por meio da exploração de permissões incorretas as quais permitiram a recuperação das flags.

2 Reconhecimento

Primeiramente se estudou a superfície de ataque exposta pela máquina, ou seja, portas abertas e serviços em execução. Para tal, foi usado o nmap com o seguinte comando:

2.1 Enumeração de portas

```
$ nmap -T4 -A -p- <IP>
```

O comando define uma varredura agressiva do alvo em todos os valores de porta possíveis (-p-), com alta geração de tráfego (-T4), detecção de versão (-sV), detecção de SO (-O), execução de scripts padrão (-sC) e traceroute (–traceroute).

```
Starting Nmap 7.99 at 2026-04-10 14:36 -0300
Nmap scan report for TARGET_IP
Host is up (0.17s latency).
Not shown: 65532 filtered tcp ports (no-response)

PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 1 disallowed entry
|_/
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol
    2.0)

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap done: 1 IP address (1 host up) scanned in 533.73 seconds
```

Com essa saída, pode-se observar a presença de um serviço FTP ativo que permite login anônimo, logo, com acesso a arquivos públicos. Em adição, um serviço TCP e um SSH.

```
$ ftp <IP>
ftp> ls -la
drwxr-xr-x    3 ftp      ftp          4096 Aug 17  2019 .
drwxr-xr-x    3 ftp      ftp          4096 Aug 17  2019 ..
drwxr-xr-x    2 ftp      ftp          4096 Aug 17  2019 pub
ftp> cd pub
ftp> ls -la
drwxr-xr-x    2 ftp      ftp          4096 Aug 17  2019 .
drwxr-xr-x    3 ftp      ftp          4096 Aug 17  2019 ..
-rw-r--r--    1 ftp      ftp           166 Aug 17  2019 ForMitch.txt
```

Após o login anônimo, os arquivos de acesso público foram listados. Como observado nos comandos acima, foi achada uma pasta pub a qual contém um arquivo de texto ForMitch.txt.

```
$ cat ForMitch.txt
Dammit man... you'te the worst dev i've seen. You set the same pass for the system
     user, and the password is so weak... i cracked it in seconds. Gosh... what a
    mess!
```

De acordo com o texto, o desenvolvedor Mitch configurou o sistema com uma senha fraca.

2.2 Enumeração de diretórios

```
$ feroxbuster -u http://<IP> -w wordlists/directory-list-2.3-medium.txt -x php,txt
    , html
```

Com uso da ferramenta Feroxbuster, foram explorados os diretórios expostos pelo serviço TCP. No comando, é indicado o uso de uma lista de diretórios com extensões php, txt e html, comuns para serviços web.

Assim, foram encontrados alguns diretórios de interesse, principalmente http://<IP>/simple/admin, o qual expõe uma tela de login.

Figure 1: Tela de login do serviço CMS.

3 Exploração

Dentre os diretórios de interesse encontrados, está o http://<IP>/simple. Nele, é possível encontrar a versão do serviço CMS Made Simple implementada.

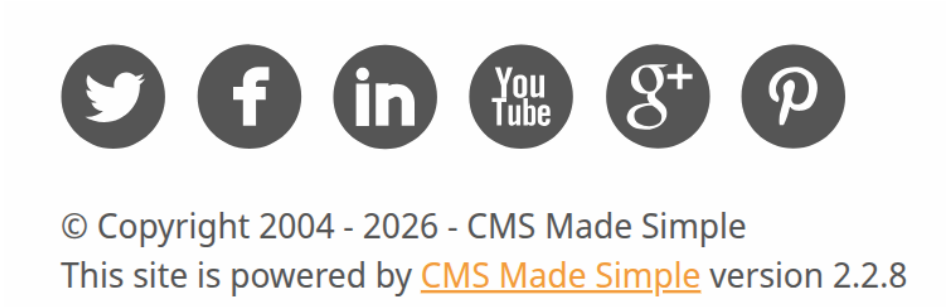

Figure 2: Versão.

De acordo com a vulnerabilidade catalogada sob o identificador *CVE-2019-9053* no banco de dados do NIST, a versão identificada do CMS Made Simple apresenta uma falha de injeção SQL do tipo time-based.

Um exploit público para esta vulnerabilidade está disponível no repositório mantido por e-renna no link: https://github.com/e-renna/CVE-2019-9053

Com o comando:

```
$ python exploit.py --w <WORDLIST> -u http://<IP>/simple/admin/login.php --crack
```

Com o script e a wordlist rockyou75.txt, foi possível a quebra da hash da senha.

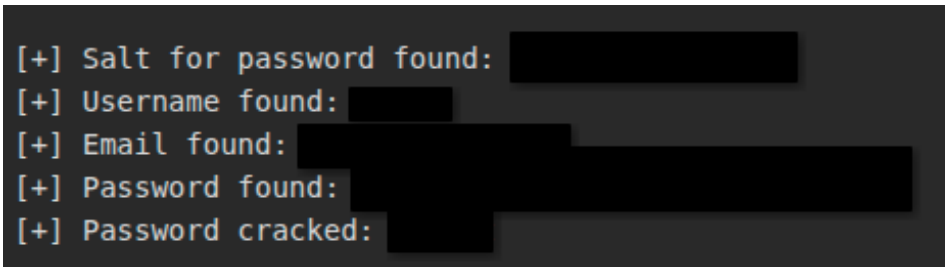

Figure 3: Resultado do comando.

Com a posse da credencial, iniciou-se a conexão SSH:

```
$ ssh -p 2222 <USERNAME>@<IP>
```

Logo após entrar, já foi possível encontrar a flag de usuário:

```
<USERNAME>@<IP>:~/Desktop$ cat user.txt
<FLAG>
```

Depois, executou-se o comando sudo -l, a fim de identificar comandos executáveis como root.

```
<USERNAME>@<IP>:~/Desktop$ sudo -l
User <USERNAME> may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

Com isso, nota-se que o usuário possui permissão para executar o comando vim como root sem restrições adicionais. Com ele, foi possível recuperar a última flag.

A fim de responder uma das perguntas na página do desafio, subiu-se um diretório para encontrar o outro usuário na máquina, com os seguintes comandos.

```
$ cd ..
$ ls
```

4 Escalação de privilégios

Como visto na seção anterior, o usuário possui acesso ao comando sudo vim.

Normalmente, a flag de root se encontra em /root/root.txt. Ao tentar:

```
# sudo vim /root/root.txt
```

foi possível ver a última flag através do editor de texto.

5 Conclusão

A cadeia de exploração completa compreendeu cinco etapas principais. Primeiramente, o reconhecimento ativo com Nmap identificou três serviços: FTP anônimo (porta 21), HTTP (porta 80) e SSH (porta 2222). Em seguida, a enumeração de diretórios com Feroxbuster revelou o painel administrativo do CMS Made Simple na versão 2.2.8. A terceira etapa consistiu na exploração da vulnerabilidade CVE-2019-9053 (time-based SQL injection), utilizando um exploit para extrair o hash da senha do usuário, posteriormente quebrado com a wordlist rockyou75.txt. De posse das credenciais, estabeleceu-se conexão SSH na porta 2222, obtendo a flag de usuário no diretório /Desktop. Finalmente, a verificação de privilégios com sudo -l revelou que o usuário poderia executar /usr/bin/vim como root sem senha, permitindo a leitura direta da flag de root em /root/root.txt.

References

[1] SECLISTS. *rockyou-75.txt*. Daniel Miessler. Disponível em: https://github.com/danielmiessler/SecLists/blob/master/Passwords/Leaked-Databases/rockyou-75.txt. Acesso em: abr. 2026.

[2] NIST. *CVE-2019-9053 - CMS Made Simple SQL Injection Vulnerability*. National Vulnerability Database, 2019. Disponível em: https://nvd.nist.gov/vuln/detail/CVE-2019-9053.

[3] E-RENNA. *CVE-2019-9053 - CMS Made Simple Time-based SQL Injection Exploit*. GitHub, 2020. Disponível em: https://github.com/e-renna/CVE-2019-9053.

6 Ferramentas

Name	**Description**	**Link**
Nmap	Escaneador de rede e vulnerabilidade	`https://nmap.org/`
Feroxbuster	Ferramenta de descoberta recursiva	`https://github.com/epi052/feroxbuster`